

PAYFLOW LTD

Risk Remediation Plan

ISO 27001:2022 Aligned (Clause 6.1.2 — Risk Assessment)

Version: 1.0

Date: June 2026

Prepared by: Bhuvana Kodathi Srinivas

Classification: Confidential

EXECUTIVE SUMMARY

This Risk Remediation Plan has been developed for PayFlow Ltd, a 30-person Dublin-based fintech startup providing a cloud-based payment processing platform for SME clients across Ireland and the EU. The plan documents prioritised remediation actions for all 26 risks identified in the PayFlow Ltd Information Security Risk Register.

Risks were assessed using a 5x5 Likelihood x Impact scoring matrix aligned to ISO 27001:2022 Clause 6.1.2 (Information Security Risk Assessment). The remediation actions below are grouped by priority level to enable PayFlow's leadership team to allocate resources effectively and address the most critical threats first.

Risk Summary

Risk Level	Count	Percentage
Critical	8	31%
High	16	61%
Medium	2	8%
Total	26	100%

Remediation Timeline

Target	Risks	Priority
Q1 2026 (Immediate)	18	All Critical + majority of High
Q2 2026 (90 days)	8	Remaining High + Medium

CRITICAL PRIORITY REMEDIATIONS

The following 8 risks carry the highest risk scores (15-25) and require immediate remediation. These represent the greatest threat to PayFlow's operations, customer data, and regulatory standing.

R-001 — Ransomware attack encrypting payment processing systems

Category: Cybersecurity

Risk Score: $5 \times 5 = 25$ (Critical)

Risk Owner: IT Department

Threat Source: External threat actor

Current Controls / Gaps: Insufficient endpoint protection and backup testing

Remediation Actions:

- Deploy EDR solution across all endpoints.
- Test backup restore procedures monthly.
- Implement network segmentation to isolate payment processing systems from general office network.
- Conduct ransomware tabletop exercise with incident response team.

Target Completion: Q1 2026

R-002 — Phishing attack leading to credential compromise

Category: Cybersecurity

Risk Score: $5 \times 4 = 20$ (Critical)

Risk Owner: IT Department

Threat Source: External threat actor / social engineering

Current Controls / Gaps: No email filtering or security awareness training in place

Remediation Actions:

- Deploy email filtering with attachment and link scanning.
- Launch quarterly phishing simulation programme for all staff.
- Enforce MFA on all accounts immediately.
- Track phishing simulation results and provide targeted retraining for staff who fail.

Target Completion: Q1 2026

R-003 — SQL injection attack on payment processing API

Category: Cybersecurity

Risk Score: $4 \times 5 = 20$ (Critical)

Risk Owner: Engineering Lead

Threat Source: External threat actor / automated scanning

Current Controls / Gaps: No SAST or penetration testing conducted to date

Remediation Actions:

- Engage a qualified third-party penetration testing provider and conduct an annual penetration test.
- Implement Static Application Security Testing (SAST) in the CI/CD pipeline.
- Enforce OWASP Top 10 compliance across all application code.

- Remediate all critical and high findings before production deployment.

Target Completion: Q1 2026

R-004 — Unauthorised access to customer payment data via stolen credentials

Category: Cybersecurity

Risk Score: 4 x 5 = 20 (Critical)

Risk Owner: IT Department

Threat Source: External or insider threat

Current Controls / Gaps: MFA not enforced on all systems; access reviews not conducted quarterly

Remediation Actions:

- Enforce MFA on all cloud systems, remote access, and privileged accounts immediately.
- Implement role-based access control (RBAC) across all applications.
- Conduct quarterly access reviews — revoke access for leavers within 24 hours.
- Log all access to customer payment data.

Target Completion: Q1 2026

R-010 — GDPR enforcement action due to inadequate data protection practices

Category: Compliance & Regulatory

Risk Score: 4 x 5 = 20 (Critical)

Risk Owner: Legal / DPO

Threat Source: Regulatory / Data Protection Commission

Current Controls / Gaps: No formal GDPR compliance programme; DPO not yet appointed

Remediation Actions:

- Appoint a Data Protection Officer (DPO).
- Conduct a comprehensive GDPR gap analysis across all data processing activities.
- Implement data protection policies covering lawful basis for processing, data subject rights, and breach notification procedures.
- Establish a Record of Processing Activities (ROPA) as required under GDPR Article 30.

Target Completion: Q1 2026

R-011 — PCI-DSS non-compliance leading to loss of card processing rights

Category: Compliance & Regulatory

Risk Score: 4 x 5 = 20 (Critical)

Risk Owner: IT / Legal

Threat Source: Regulatory / Payment card schemes

Current Controls / Gaps: PCI-DSS assessment not yet conducted; cardholder data environment not formally scoped

Remediation Actions:

- Engage a Qualified Security Assessor (QSA) to conduct a PCI-DSS gap assessment.
- Formally scope the cardholder data environment (CDE).
- Remediate all identified gaps — prioritise encryption, access control, and logging requirements.
- Achieve PCI-DSS certification before processing any card payments.

Target Completion: Q1 2026

R-014 — Third-party payment processor suffers a data breach exposing PayFlow customer data

Category: Third-Party / Vendor

Risk Score: 4 x 5 = 20 (Critical)

Risk Owner: Legal / ISO Officer

Threat Source: Vendor security failure

Current Controls / Gaps: No vendor security assessments conducted; no security clauses in contracts

Remediation Actions:

- Conduct formal vendor risk assessments for all tier-1 suppliers before onboarding.
- Include security clauses, breach notification requirements (within 24 hours), data handling obligations, and right-to-audit provisions in all vendor contracts.
- Review vendor SOC 2 or ISO 27001 reports annually.
- Maintain a vendor risk register.

Target Completion: Q1 2026

R-021 — Payment fraud resulting in significant financial loss to PayFlow or its merchants

Category: Financial

Risk Score: 4 x 5 = 20 (Critical)

Risk Owner: IT / Finance

Threat Source: Fraudulent transactions / external threat

Current Controls / Gaps: No fraud detection system in place; no transaction monitoring

Remediation Actions:

- Implement real-time transaction monitoring and fraud detection system with automated alerting.
- Define chargeback management procedures.
- Establish fraud thresholds — transactions exceeding thresholds require manual review.
- Conduct monthly fraud trend analysis and report to senior management.

Target Completion: Q1 2026

HIGH PRIORITY REMEDIATIONS

The following 16 risks carry high risk scores (8-14) and must be remediated within 90 days. While not as immediately critical, these gaps represent significant exposure if left unaddressed.

R-005 — DDoS attack causing platform unavailability

Category: Cybersecurity

Risk Score: $3 \times 4 = 12$ (High)

Risk Owner: IT Department

Threat Source: External threat actor

Current Controls / Gaps: No DDoS mitigation service in place; single-region AWS deployment

Remediation Actions:

- Implement AWS Shield Standard for DDoS protection.
- Configure auto-scaling for critical production systems to handle traffic spikes.
- Deploy to multiple AWS availability zones for redundancy.
- Establish a DDoS response procedure.

Target Completion: Q2 2026

R-006 — System outage due to single point of failure in AWS infrastructure

Category: Operational

Risk Score: $3 \times 5 = 15$ (High)

Risk Owner: IT Department

Threat Source: Infrastructure failure

Current Controls / Gaps: No multi-region deployment; RTO and RPO not formally defined

Remediation Actions:

- Deploy critical systems across multiple AWS availability zones.
- Define and document Recovery Time Objective (RTO) of 4 hours and Recovery Point Objective (RPO) of 24 hours.
- Conduct semi-annual failover testing exercises.
- Monitor AWS Service Health Dashboard continuously.

Target Completion: Q1 2026

R-007 — Data loss due to backup failure

Category: Operational

Risk Score: $3 \times 5 = 15$ (High)

Risk Owner: IT Department

Threat Source: Technical failure

Current Controls / Gaps: Backups not tested regularly; no off-site backup storage

Remediation Actions:

- Implement automated daily encrypted backups to a separate AWS region.
- Test restore procedures monthly and document results.
- Retain backup logs for audit purposes.

- Define backup retention periods per data category.

Target Completion: Q1 2026

R-012 — PSD2 non-compliance — failure to implement Strong Customer Authentication

Category: Compliance & Regulatory

Risk Score: 3 x 5 = 15 (High)

Risk Owner: Engineering Lead

Threat Source: Regulatory / Central Bank of Ireland

Current Controls / Gaps: SCA not fully implemented across all payment flows

Remediation Actions:

- Implement Strong Customer Authentication (SCA) across all payment flows.
- Engage legal counsel to verify full PSD2 compliance.
- Document compliance evidence for potential Central Bank audit.
- Maintain records of all SCA exemption decisions.

Target Completion: Q2 2026

R-015 — AWS service outage causing platform unavailability

Category: Third-Party / Vendor

Risk Score: 3 x 5 = 15 (High)

Risk Owner: IT Department

Threat Source: Cloud provider failure

Current Controls / Gaps: No multi-region failover; over-reliance on single AWS region

Remediation Actions:

- Configure multi-region AWS deployment with automated failover for critical systems.
- Review AWS SLA terms and shared responsibility model.
- Implement automated health monitoring and alerting for AWS service status changes.

Target Completion: Q2 2026

R-025 — Insider threat — disgruntled employee deliberately exfiltrates customer payment data

Category: People / Human

Risk Score: 3 x 5 = 15 (High)

Risk Owner: IT / HR

Threat Source: Malicious insider

Current Controls / Gaps: No DLP controls; no user behaviour monitoring; access reviews not conducted

Remediation Actions:

- Implement Data Loss Prevention (DLP) tooling to detect and prevent unauthorised data transfers.
- Conduct quarterly access reviews for all staff.
- Monitor privileged user activity and investigate anomalies.
- Implement immediate access revocation as part of employee offboarding procedures.

Target Completion: Q1 2026

R-008 — Unauthorised system change causing platform instability

Category: Operational

Risk Score: 3 x 4 = 12 (High)

Risk Owner: IT Department

Threat Source: Internal human error

Current Controls / Gaps: No formal change management process in place

Remediation Actions:

- Implement a formal change management procedure with documented approval sign-off, risk assessment, pre-implementation testing, and rollback plans.
- Classify changes as Standard, Normal, or Emergency.
- Retain change records for a minimum of 12 months.

Target Completion: Q2 2026

R-009 — Payment processing errors due to software defect in production

Category: Operational

Risk Score: 3 x 4 = 12 (High)

Risk Owner: Engineering Lead

Threat Source: Development error

Current Controls / Gaps: No separation between development and production environments

Remediation Actions:

- Enforce strict environment separation — development, testing, and production must be fully isolated on AWS.
- Implement a pre-production testing gate including security and functional testing before all deployments.
- Prohibit real customer data in non-production environments.

Target Completion: Q1 2026

R-013 — Failure to notify DPC within 72 hours of a data breach

Category: Compliance & Regulatory

Risk Score: 3 x 4 = 12 (High)

Risk Owner: Legal / ISO Officer

Threat Source: Regulatory / GDPR Article 33

Current Controls / Gaps: No incident response plan or breach notification procedure in place

Remediation Actions:

- Develop and document an Incident Response Plan (IRP) with a clear 72-hour GDPR breach notification procedure.
- Assign incident response roles and responsibilities.
- Conduct tabletop exercises semi-annually to test the IRP.
- Maintain an incident log for all reported events.

Target Completion: Q1 2026

R-016 — Third-party software library vulnerability exploited in PayFlow application

Category: Third-Party / Vendor

Risk Score: 4 x 4 = 16 (High)

Risk Owner: Engineering Lead

Threat Source: Supply chain attack

Current Controls / Gaps: No software composition analysis conducted on third-party libraries

Remediation Actions:

- Implement Software Composition Analysis (SCA) tooling in the CI/CD pipeline.
- Review and update all third-party dependencies monthly.
- Subscribe to vulnerability alerts (e.g.
- GitHub Dependabot, Snyk) for all critical libraries.
- Block deployment if critical vulnerabilities are detected.

Target Completion: Q1 2026

R-017 — Subcontractor accesses PayFlow customer data without authorisation

Category: Third-Party / Vendor

Risk Score: 3 x 4 = 12 (High)

Risk Owner: Legal

Threat Source: Vendor / insider threat

Current Controls / Gaps: No restrictions on subcontractor data access; no NDAs in place

Remediation Actions:

- Implement subcontractor access controls with least-privilege principles.
- Require NDAs before any data access is granted.
- Conduct annual vendor access reviews.
- Maintain access logs for all subcontractor activity.

Target Completion: Q2 2026

R-018 — Theft of employee laptop containing sensitive customer data

Category: Physical & Environmental

Risk Score: 3 x 4 = 12 (High)

Risk Owner: IT Department

Threat Source: Physical theft

Current Controls / Gaps: Device encryption not enforced on all laptops; no MDM in place

Remediation Actions:

- Enforce full disk encryption (BitLocker/FileVault) on all company devices.
- Deploy Mobile Device Management (MDM) with remote wipe capability.
- Implement mandatory incident reporting for all lost or stolen devices.
- Revoke access tokens remotely within 1 hour of a report.

Target Completion: Q1 2026

R-022 — Insufficient cyber insurance coverage leaving PayFlow exposed to breach costs

Category: Financial

Risk Score: 3 x 4 = 12 (High)

Risk Owner: Finance Director

Threat Source: Financial planning gap

Current Controls / Gaps: No cyber insurance policy in place

Remediation Actions:

- Obtain a comprehensive cyber insurance policy covering data breach response costs, ransomware, regulatory fines, and business interruption.
- Review coverage limits annually and adjust based on business growth and risk profile changes.

Target Completion: Q1 2026

R-023 — Security budget constraints limiting ability to implement critical controls

Category: Financial

Risk Score: 3 x 4 = 12 (High)

Risk Owner: CEO / Finance

Threat Source: Internal financial risk

Current Controls / Gaps: Security budget not formally allocated; controls deprioritised against product development

Remediation Actions:

- Formally allocate an annual information security budget as a line item.
- Present a risk-based business case to the board linking budget requests to specific risk register items.
- Demonstrate ROI by quantifying potential breach costs against control implementation costs.

Target Completion: Q1 2026

R-024 — Key person dependency — critical security knowledge held by single staff member

Category: People / Human

Risk Score: 4 x 4 = 16 (High)

Risk Owner: ISO Officer / HR

Threat Source: Human / organisational risk

Current Controls / Gaps: No documented security procedures; knowledge not transferred across team

Remediation Actions:

- Document all critical security procedures and operational runbooks.
- Implement a cross-training programme ensuring at least 2 staff members are trained per function.
- Maintain a formal succession plan for key security roles.
- Review knowledge transfer coverage quarterly.

Target Completion: Q2 2026

R-026 — Human error leading to accidental disclosure of customer data

Category: People / Human

Risk Score: 4 x 4 = 16 (High)

Risk Owner: ISO Officer

Threat Source: Unintentional insider threat

Current Controls / Gaps: No data handling training; no data classification policy implemented

Remediation Actions:

- Implement a data classification policy (Confidential / Internal / Public).

- Deliver mandatory data handling training to all staff on onboarding and annually.
- Implement email DLP rules to flag and block emails containing sensitive data patterns (e.g. card numbers, IBANs).
- Conduct quarterly data handling compliance spot-checks.

Target Completion: Q1 2026

MEDIUM PRIORITY REMEDIATIONS

The following 2 risks carry medium risk scores (4-7) and should be addressed within 6 months. These represent lower but non-negligible exposure.

R-019 — Office flood or fire causing loss of on-site equipment and data

Category: Physical & Environmental

Risk Score: $2 \times 4 = 8$ (Medium)

Risk Owner: IT / Facilities

Threat Source: Environmental hazard

Current Controls / Gaps: No business continuity plan; no off-site data storage

Remediation Actions:

- Develop and document a Business Continuity Plan (BCP).
- Ensure all critical data is stored in AWS with daily off-site encrypted backups.
- Install fire suppression and environmental monitoring systems in the office.
- Test BCP annually.

Target Completion: Q2 2026

R-020 — Unauthorised physical access to PayFlow office gaining access to systems

Category: Physical & Environmental

Risk Score: $2 \times 4 = 8$ (Medium)

Risk Owner: Facilities Manager

Threat Source: Physical security breach

Current Controls / Gaps: No key card access control; visitor log not maintained

Remediation Actions:

- Implement key card access control system at all entry points.
- Enforce a visitor sign-in and escort policy.
- Install CCTV at all entry and exit points with 30-day footage retention.
- Retain access logs for a minimum of 12 months.

Target Completion: Q2 2026